

IT AND OPERATIONS COMPLIANCE POLICY

Internal Policy Document

Version 1.0

Effective Date: November 24, 2025

CONFIDENTIAL - INTERNAL USE ONLY

TABLE OF CONTENTS

Section	Page
1. Introduction and Purpose	3
2. Scope and Applicability	3
3. Information Security Policy	4
4. Access Control and Authentication	5
5. Data Protection and Privacy	6
6. Network Security	7
7. Operational Security	8
8. Asset Management	9
9. Incident Response and Management	10
10. Business Continuity and Disaster Recovery	11
11. Vendor and Third-Party Management	12
12. Compliance and Audit	13
13. Training and Awareness	14
14. Policy Enforcement and Violations	14
15. Policy Review and Updates	15

1. INTRODUCTION AND PURPOSE

This IT and Operations Compliance Policy establishes the framework for ensuring the security, integrity, availability, and confidentiality of organizational information and technology assets. This policy is designed to protect our organization from cybersecurity threats, ensure regulatory compliance, and maintain operational excellence across all IT and operational functions.

1.1 Objectives

The primary objectives of this policy are to: (a) Protect organizational data and information systems from unauthorized access, disclosure, modification, or destruction; (b) Ensure compliance with applicable legal, regulatory, and contractual requirements; (c) Establish clear responsibilities and accountabilities for IT security and operations; (d) Minimize operational risks and business disruptions; (e) Promote a culture of security awareness and compliance throughout the organization; and (f) Enable secure and efficient business operations while maintaining appropriate controls.

1.2 Policy Authority

This policy is established under the authority of the Chief Information Officer (CIO) and Chief Operations Officer (COO), with approval from the Executive Leadership Team and Board of Directors. All employees, contractors, vendors, and third parties with access to organizational systems must comply with this policy.

2. SCOPE AND APPLICABILITY

2.1 Coverage

This policy applies to all information technology resources, operational systems, data, and facilities owned, leased, or managed by the organization. This includes but is not limited to: servers, workstations, mobile devices, network equipment, software applications, cloud services, databases, communication systems, and physical infrastructure.

2.2 Applicable Personnel

This policy applies to: (a) All full-time and part-time employees; (b) Contractors and temporary staff; (c) Vendors and service providers with system access; (d) Board members and advisors; (e) Interns and volunteers; and (f) Any third party granted access to organizational systems or data.

2.3 Geographic Scope

This policy applies to all organizational operations globally, including domestic and international offices, remote work locations, and off-site facilities. Where local laws or regulations impose stricter requirements, those requirements shall supersede this policy.

3. INFORMATION SECURITY POLICY

3.1 Information Classification

All organizational information must be classified according to its sensitivity and criticality. The organization uses the following classification levels:

Level	Description	Examples
Public	Information approved for public disclosure	Marketing materials, public websites
Internal	General business information for internal use	Internal policies, org charts
Confidential	Sensitive business information	Financial data, contracts, HR records
Restricted	Highly sensitive information	Trade secrets, customer PII, security keys

3.2 Information Handling Requirements

Information must be handled according to its classification level. Confidential and Restricted information requires: (a) Encryption during transmission and at rest; (b) Secure storage with restricted access; (c) Formal authorization for access and sharing; (d) Secure disposal methods when no longer needed; and (e) Detailed audit logging of all access and modifications.

3.3 Acceptable Use

IT resources must be used primarily for legitimate business purposes. Personal use must be minimal, non-disruptive, and comply with all organizational policies. Prohibited activities include: accessing, storing, or distributing illegal, offensive, or inappropriate content; using systems for personal financial gain; compromising security controls or attempting unauthorized access; installing unauthorized software or hardware; and sharing credentials or allowing unauthorized use of accounts.

4. ACCESS CONTROL AND AUTHENTICATION

4.1 User Account Management

All system access must be through individual user accounts. Shared accounts are prohibited except where specifically approved and documented. Account provisioning must follow the principle of least privilege, granting only the minimum access necessary for job functions. User accounts must be: (a) Created through formal request and approval processes; (b) Reviewed regularly for appropriateness; (c) Disabled immediately upon termination or extended leave; and (d) Recertified at least annually by department managers.

4.2 Password Requirements

All user passwords must meet the following minimum requirements: (a) Minimum length of 12 characters; (b) Combination of uppercase letters, lowercase letters, numbers, and special characters; (c) Cannot contain username, real name, or common dictionary words; (d) Must be changed every 90 days for standard accounts and every 60 days for privileged accounts; (e) Cannot reuse last 12 passwords; and (f) Account lockout after 5 consecutive failed login attempts.

4.3 Multi-Factor Authentication (MFA)

Multi-factor authentication is mandatory for: (a) All remote access to corporate networks; (b) Access to systems containing Confidential or Restricted data; (c) All administrative and privileged accounts; (d) Cloud-based business applications; and (e) Virtual Private Network (VPN) connections. MFA must use time-based one-time passwords (TOTP), hardware tokens, or biometric authentication methods.

4.4 Privileged Access Management

Administrative and privileged accounts require additional controls: (a) Separate accounts for administrative tasks versus standard user activities; (b) Enhanced monitoring and logging of all privileged activities; (c) Just-in-time access provisioning where technically feasible; (d) Regular review and approval by IT management; (e) Privileged password rotation every 30 days; and (f) Mandatory use of privileged access management (PAM) tools for critical systems.

5. DATA PROTECTION AND PRIVACY

5.1 Data Protection Principles

The organization is committed to protecting all data in its custody according to applicable privacy laws and regulations including GDPR, CCPA, HIPAA, and other relevant frameworks. Data protection principles include: (a) Lawfulness, fairness, and transparency in data processing; (b) Purpose limitation and data minimization; (c) Accuracy and timely updates of personal data; (d) Storage limitation with defined retention periods; (e) Integrity and confidentiality through appropriate security measures; and (f) Accountability with documented compliance measures.

5.2 Personal Data Handling

Personal data and personally identifiable information (PII) require special handling: (a) Collection limited to legitimate business purposes with documented legal basis; (b) Explicit consent obtained where required; (c) Access restricted to authorized personnel with business need; (d) Encryption required for transmission and storage; (e) Data subject rights respected including access, correction, and deletion requests; and (f) Cross-border transfers conducted only with appropriate safeguards.

5.3 Data Encryption

Encryption requirements vary by data classification: (a) Restricted data: AES-256 encryption at rest and TLS 1.3 or higher in transit; (b) Confidential data: AES-256 or equivalent encryption; (c) Internal data: Encryption recommended for mobile devices and remote access; (d) Public data: No encryption required unless other policies dictate. Encryption keys must be managed through approved key management systems with regular rotation and secure storage.

5.4 Data Retention and Disposal

Data retention periods must comply with legal requirements and business needs. Data must be securely disposed of when retention periods expire or when no longer needed. Disposal methods include: (a) Digital data: Cryptographic erasure or DOD 5220.22-M standard wiping; (b) Physical media: Cross-cut shredding or certified destruction services; (c) Hardware: Degaussing, physical destruction, or certified disposal; and (d) All disposal activities must be documented with certificates of destruction maintained.

6. NETWORK SECURITY

6.1 Network Architecture

The organization maintains a defense-in-depth network architecture with multiple security layers: (a) Network segmentation separating production, development, and guest networks; (b) Demilitarized zones (DMZ) for internet-facing services; (c) Firewalls at network boundaries with default-deny rule sets; (d) Intrusion detection and prevention systems (IDS/IPS) monitoring network traffic; and (e) Regular network security assessments and penetration testing.

6.2 Wireless Network Security

Wireless networks require enhanced security controls: (a) WPA3 or WPA2-Enterprise encryption mandatory; (b) Separate guest wireless networks isolated from corporate networks; (c) 802.1X authentication for corporate wireless access; (d) Wireless intrusion detection systems monitoring for rogue access points; (e) Regular wireless security assessments; and (f) Automatic disconnection after 30 minutes of inactivity.

6.3 Remote Access

All remote access to corporate networks must use approved secure channels: (a) Virtual Private Network (VPN) required for remote network access; (b) Multi-factor authentication mandatory; (c) Full-disk encryption required on all devices with remote access capabilities; (d) Remote desktop connections only through approved secure gateways; (e) Regular monitoring of remote access logs; and (f) Split-tunneling prohibited for VPN connections.

6.4 Network Monitoring

Continuous network monitoring is essential for security: (a) Security Information and Event Management (SIEM) system collecting and analyzing security logs; (b) Network traffic analysis for anomaly detection; (c) 24/7 security operations center (SOC) monitoring for critical systems; (d) Automated alerting for security events; (e) Regular review of firewall and IDS/IPS logs; and (f) Network flow analysis to identify unauthorized data transfers.

7. OPERATIONAL SECURITY

7.1 Change Management

All changes to production systems must follow formal change management processes: (a) Change requests documented with business justification and risk assessment; (b) Technical review and approval before implementation; (c) Testing in non-production environments; (d) Documented back-out procedures; (e) Change advisory board (CAB) approval for high-risk changes; (f) Post-implementation review; and (g) Emergency change procedures for critical security patches.

7.2 Patch Management

Timely patching is critical for security: (a) Critical security patches applied within 7 days; (b) High severity patches applied within 30 days; (c) Medium and low severity patches applied within 60 days; (d) Automated patch deployment where possible; (e) Patch testing in non-production environments; (f) Vulnerability scanning before and after patching; and (g) Documented exceptions for systems that cannot be patched within standard timeframes.

7.3 System Logging and Monitoring

Comprehensive logging enables security monitoring and forensic analysis: (a) Centralized log collection and retention for minimum 90 days (1 year for critical systems); (b) Logs protected against unauthorized modification or deletion; (c) Time synchronization across all systems using NTP; (d) Logging of security-relevant events including authentication, authorization changes, and data access; (e) Regular log review and analysis; and (f) Automated correlation and alerting for suspicious activities.

7.4 Vulnerability Management

Proactive vulnerability identification and remediation: (a) Quarterly vulnerability scans of all network-connected systems; (b) Annual penetration testing by qualified third parties; (c) Vulnerability prioritization based on risk and exploitability; (d) Documented remediation plans with timelines; (e) Continuous vulnerability monitoring for critical systems; and (f) Regular reporting to management on vulnerability status.

8. ASSET MANAGEMENT

8.1 IT Asset Inventory

Accurate asset inventory is essential for security and compliance: (a) Comprehensive inventory of all IT assets including hardware, software, and licenses; (b) Asset attributes including owner, location, configuration, and criticality; (c) Automated discovery tools supplemented by manual verification; (d) Quarterly inventory reconciliation and updates; (e) Asset tagging for physical equipment; and (f) Configuration management database (CMDB) maintained for all critical assets.

8.2 Hardware Asset Lifecycle

Hardware assets must be managed throughout their lifecycle: (a) Procurement through approved vendors with security requirements; (b) Secure configuration before deployment; (c) Regular maintenance and updates; (d) Secure disposal or repurposing at end-of-life; (e) Data sanitization before disposal or redeployment; and (f) Asset tracking from acquisition to disposal.

8.3 Software Asset Management

Software must be properly licensed and managed: (a) Only authorized and approved software may be installed; (b) Software licenses tracked and maintained; (c) Regular software audits to ensure compliance; (d) Removal of unauthorized or end-of-life software; (e) Software bill of materials (SBOM) maintained for custom applications; and (f) Open source software usage tracked and reviewed for licensing compliance.

8.4 Mobile Device Management

Mobile devices require special management: (a) All corporate mobile devices enrolled in Mobile Device Management (MDM) platform; (b) Device encryption and passcode requirements enforced; (c) Remote wipe capability enabled; (d) Application whitelisting for corporate data access; (e) Bring Your Own Device (BYOD) program with containerization for corporate data; and (f) Lost or stolen devices immediately reported and remotely wiped.

9. INCIDENT RESPONSE AND MANAGEMENT

9.1 Incident Response Framework

The organization maintains a comprehensive incident response capability: (a) Incident Response Team (IRT) with defined roles and responsibilities; (b) 24/7 incident reporting channels; (c) Documented incident response procedures; (d) Regular incident response exercises and tabletop drills; (e) Communication protocols for stakeholder notification; and (f) Post-incident review and lessons learned process.

9.2 Incident Classification

Incidents are classified by severity to ensure appropriate response:

Severity	Response Time	Examples
Critical	15 minutes	Data breach, ransomware, critical system failure
High	1 hour	Compromised accounts, malware infection, DDoS attack
Medium	4 hours	Policy violations, minor security events, system errors
Low	24 hours	Failed login attempts, spam, minor configuration issues

9.3 Incident Reporting Requirements

All employees must promptly report security incidents: (a) Suspected security incidents reported immediately to IT Security or through incident hotline; (b) Detailed incident documentation including date, time, description, and impact; (c) Preservation of evidence where possible; (d) No independent remediation attempts that could compromise investigation; and (e) Cooperation with incident response team throughout investigation.

9.4 Breach Notification

Data breaches require specific notification procedures: (a) Legal and compliance teams notified immediately; (b) Breach assessment completed within 24 hours; (c) Regulatory notifications made within required timeframes (typically 72 hours for GDPR); (d) Affected individuals notified as required by law; (e) Public relations and executive communications coordinated; and (f) Breach response documented for regulatory review.

10. BUSINESS CONTINUITY AND DISASTER RECOVERY

10.1 Business Continuity Planning

The organization maintains business continuity capabilities to ensure operational resilience: (a) Business Impact Analysis (BIA) conducted annually to identify critical functions; (b) Recovery Time Objectives (RTO) and Recovery Point Objectives (RPO) defined for all critical systems; (c) Business Continuity Plans (BCP) documented and maintained; (d) Alternate work locations identified for critical functions; (e) Annual BCP testing and exercises; and (f) Plan updates following major organizational changes.

10.2 Disaster Recovery

IT disaster recovery ensures system availability: (a) Disaster Recovery Plan (DRP) maintained for all critical IT systems; (b) Regular backups with off-site storage; (c) High availability architecture for critical systems; (d) Disaster recovery site maintained with regular testing; (e) System recovery procedures documented and tested; and (f) Semi-annual disaster recovery exercises conducted.

10.3 Data Backup Requirements

Comprehensive backup strategy protects organizational data: (a) Daily incremental backups of all critical data; (b) Weekly full backups retained for 30 days; (c) Monthly backups retained for 1 year; (d) Backup encryption using AES-256; (e) Off-site backup storage geographically separated from primary location; (f) Quarterly backup restoration testing; (g) 3-2-1 backup strategy (3 copies, 2 different media, 1 off-site); and (h) Immutable backups for ransomware protection.

10.4 Crisis Management

Crisis management ensures coordinated response to major incidents: (a) Crisis Management Team (CMT) with executive leadership; (b) Crisis communication protocols for internal and external stakeholders; (c) Emergency notification systems for rapid team mobilization; (d) Crisis management center with backup location; (e) Regular crisis simulation exercises; and (f) Post-crisis review and continuous improvement.

11. VENDOR AND THIRD-PARTY MANAGEMENT

11.1 Vendor Risk Assessment

All vendors with access to organizational data or systems must undergo risk assessment: (a) Security questionnaires and documentation review; (b) Financial viability assessment; (c) Security certifications verification (ISO 27001, SOC 2, etc.); (d) Data handling and protection capabilities evaluation; (e) Business continuity and disaster recovery capabilities; and (f) Risk rating assigned based on data access level and criticality.

11.2 Vendor Contracts and SLAs

Vendor contracts must include appropriate security and compliance provisions: (a) Data protection and privacy requirements; (b) Security incident notification obligations; (c) Right to audit vendor security controls; (d) Data ownership and return/destruction upon contract termination; (e) Service Level Agreements (SLAs) for availability and performance; (f) Liability and indemnification clauses; (g) Compliance with applicable regulations; and (h) Subcontractor management requirements.

11.3 Ongoing Vendor Monitoring

Vendor security must be continuously monitored: (a) Annual vendor security assessments; (b) Review of vendor security certifications and audit reports; (c) Monitoring of vendor security incidents and breaches; (d) Performance against SLAs tracked and reviewed; (e) Regular security meetings with critical vendors; and (f) Vendor access reviews and recertification.

11.4 Third-Party Access Management

Third-party access requires strict controls: (a) Least privilege access granted based on business need; (b) Separate accounts for third-party users with enhanced monitoring; (c) Time-limited access with automatic expiration; (d) Multi-factor authentication mandatory; (e) Non-disclosure agreements (NDAs) signed before access granted; (f) All third-party access logged and reviewed; and (g) Immediate revocation upon contract termination or completion of work.

12. COMPLIANCE AND AUDIT

12.1 Regulatory Compliance

The organization maintains compliance with applicable regulations and standards: (a) Regular compliance assessments against relevant frameworks (GDPR, HIPAA, SOX, PCI-DSS, etc.); (b) Compliance monitoring and reporting programs; (c) Gap analysis and remediation tracking; (d) Regulatory filing and notification obligations met; (e) Compliance training for affected personnel; and (f) Documentation maintained for regulatory review.

12.2 Internal Audits

Regular internal audits ensure policy compliance: (a) Annual comprehensive IT and operations audits; (b) Quarterly focused audits on high-risk areas; (c) Access control reviews performed semi-annually; (d) Audit findings tracked with remediation plans; (e) Follow-up audits to verify remediation; and (f) Audit results reported to executive management and audit committee.

12.3 External Audits

External audits provide independent assurance: (a) Annual financial audits including IT general controls; (b) SOC 2 Type II audits for service organizations; (c) Penetration testing by qualified third parties; (d) Industry-specific compliance audits as required; (e) Cooperation with auditors and timely remediation of findings; and (f) Audit reports shared with customers and stakeholders as appropriate.

12.4 Documentation and Records Management

Comprehensive documentation supports compliance and audit activities: (a) All policies, procedures, and standards documented and accessible; (b) System documentation including architecture, configurations, and data flows; (c) Audit trails and logs retained per retention policy; (d) Evidence of compliance activities maintained; (e) Change management records preserved; and (f) Training records and acknowledgments retained.

13. TRAINING AND AWARENESS

13.1 Security Awareness Training

All personnel must complete security awareness training: (a) Mandatory security awareness training upon hire and annually thereafter; (b) Training covers phishing, social engineering, password security, data protection, and incident reporting; (c) Role-specific training for personnel with elevated access or data handling responsibilities; (d) Simulated phishing campaigns to test and improve awareness; (e) Training completion tracked and reported; and (f) Remedial training for personnel who fail assessments.

13.2 Technical Training

Technical staff require specialized training: (a) Secure coding training for development staff; (b) Security operations training for IT security personnel; (c) Privacy and compliance training for data handlers; (d) Incident response training for IRT members; (e) Industry certifications encouraged (CISSP, CISM, CEH, etc.); and (f) Regular training on new technologies and emerging threats.

13.3 Policy Acknowledgment

All personnel must acknowledge policy compliance: (a) Written acknowledgment of IT and security policies required upon hire; (b) Annual re-acknowledgment of updated policies; (c) Acknowledgments tracked and maintained in personnel records; (d) Failure to acknowledge policies may result in access restrictions; and (e) New policies communicated with mandatory acknowledgment period.

14. POLICY ENFORCEMENT AND VIOLATIONS

14.1 Compliance Monitoring

Policy compliance is actively monitored: (a) Automated compliance monitoring tools deployed; (b) Regular manual reviews of high-risk activities; (c) User activity monitoring for anomalous behavior; (d) Policy violation reports reviewed by security team; (e) Compliance metrics reported to management monthly; and (f) Trend analysis to identify systemic compliance issues.

14.2 Violation Response

Policy violations are addressed through progressive discipline: (a) First violation: Verbal warning and remedial training; (b) Second violation: Written warning and mandatory retraining; (c) Third violation: Suspension and formal disciplinary action; (d) Serious violations: Immediate investigation and potential termination; (e) All violations documented in personnel records; and (f) Criminal violations reported to law enforcement.

14.3 Exceptions Process

Policy exceptions require formal approval: (a) Written exception request with business justification; (b) Risk assessment of exception impact; (c) Compensating controls identified; (d) Approval by IT management and affected business unit; (e) Exceptions time-limited with regular review; (f) Exception register maintained and reported to audit committee; and (g) Annual review of all outstanding exceptions.

15. POLICY REVIEW AND UPDATES

15.1 Annual Policy Review

This policy is reviewed and updated annually to ensure continued relevance and effectiveness: (a) Annual comprehensive policy review by IT leadership and legal counsel; (b) Review of policy effectiveness metrics and compliance rates; (c) Assessment of changes in regulatory requirements; (d) Evaluation of emerging threats and technology changes; (e) Stakeholder feedback incorporated; and (f) Updated policy approved by executive management.

15.2 Change Management Process

Policy changes follow formal change management: (a) Proposed changes documented with justification; (b) Impact assessment on operations and compliance; (c) Stakeholder review and comment period; (d) Legal and compliance review; (e) Executive approval obtained; (f) Change communication plan developed; (g) Training and awareness activities conducted; and (h) Implementation timeline defined.

15.3 Version Control

Policy versions are carefully managed: (a) Version numbering system maintained; (b) Change history documented; (c) Previous versions archived for reference; (d) Effective dates clearly stated; (e) Distribution list maintained for policy updates; and (f) Policy repository provides access to current versions.

15.4 Contact Information

For questions regarding this policy, please contact:

Department	Contact	Email
IT Security	Chief Information Security Officer	security@organization.com
IT Operations	Chief Technology Officer	itops@organization.com
Compliance	Chief Compliance Officer	compliance@organization.com
Privacy	Data Protection Officer	privacy@organization.com

POLICY ACKNOWLEDGMENT FORM

I acknowledge that I have received, read, and understood the IT and Operations Compliance Policy. I understand that compliance with this policy is a condition of my employment/engagement with the organization. I agree to comply with all provisions of this policy and understand that violations may result in disciplinary action up to and including termination of employment or contract.

Employee/Contractor Name (Print): _____

Signature: _____

Date: _____

Department: _____

Manager Name and Signature: _____

Please sign and return this acknowledgment form to the Human Resources Department within 5 business days of receiving this policy.